iChat Pro 项目中期完成情况报告

> 编写日期：2026-10-13。核对代码基线：`f2f60ec`（生产基线），本地工作区位于 `4703ff3` 之上的修订提交。 本报告描述项目中期在文档、界面、代码三方面的真实完成情况，记录已经发现的缺陷与修复，以及需求在中期发生的调整。 未完成内容如实列出，不以文档存在代替功能交付。

一、中期总体状态

维度	状态
Phase4 原始任务	78 项中 **29** 项闭环（工程 25/54，测试 4/24），完成比例 37.2%
云端部署	已上线并可访问（HTTPS/WSS、PostgreSQL 16、Redis、持久化媒体）
Windows 客户端	P0 项 已闭环（云模式、安装卸载、连接恢复、敏感存储），P1 品牌与托盘已闭环
Android 客户端	尚未开始（0/9），无工程、无 APK
后端与消息可靠性	核心链路已闭环（统一写入、幂等、补取、排序）
文档	体系完整，含需求、设计、协议、验收、过程与课程材料
单元测试	后端 404 条、前端 62 条、桌面 36+22+24 项，本轮全部通过
主要缺口	Android、多设备与设备级安全、覆盖率与安全扫描、CI 强制门禁、原生文件集成

这是一份中期报告：项目具备可演示、可安装、可真实跨网络通信的能力，但尚未达到全部 P0 交付，不能作为结项声明。

二、文档完成情况

2.1 现行文档体系

项目文档不是一次性写作，而是区分"现行事实""原始需求""历史记录""归档附件"四类并持续维护。分类规则见 文档维护索引。

类别	代表文档	用途
项目总览	README、项目现状	用途、运行方式、已验收能力与限制
需求基线与任务	SRS V2.0、Phase4 需	114 条 `NEW-*` 需求、78

类别	代表文档	用途
	求、任务清单、需求追踪矩阵	项任务与证据状态
设计与协议	技术方案、协议 ADR、数据库设计、后端设计规范、前端设计规范	模型、幂等、补取、错误码、存储边界
安全与加密	E2EE 设计、浏览器端威胁模型、部署安全说明	密钥边界、威胁面、生产配置
部署运维	Runbook、部署架构	发布、备份、恢复、回滚、端口约束
过程与验收	完成审计、风险登记、AI 实践记录	逐卡判定、R-01–R-07 风险处置、AI 使用留痕
协作规范	GitHub 协作开发指南、项目交接文档、代码规范与测试工具	成员加入、分支、PR、评审、质量门禁
课程材料	第一/二/四次实验报告、小组分工表、交付状态报告	课程提交与答辩
归档快照	旧 PDF/Word、早期实验报告	保留当时结论，明确标注归档，不与现行状态混淆

2.2 文档维护纪律

文档体系有三条硬约束，用于避免"文档写了就算完成"：

1. 状态来源有优先级：实际代码/部署 > 具体 CI 记录 > 原生或专项验收 > 对应 Issue。需求文档和规划文档不构成完成证据。
2. 三种 **SHA** 分开记录：`main` 提交、生产部署版本、安装包 SHA 是三个独立版本证据，不得互相替代。
3. 历史结果不改写：旧实验报告和验收报告保留原日期与原结论，新结论以追加带日期说明的方式补充，不覆盖当时的测试结果。

2.3 文档同步机制

仓库在 Issue 与 PR 模板中内建了文档同步要求。PR 模板强制勾选：

- 接口、模型、协议、存储或平台行为已同步到相应现行文档，历史结果没有被覆盖；
- 实际提交包含所有预期文件，未把未运行/未完成的检查写成通过；

- 原生、跨端、迁移和发布验收范围及未完成项已如实注明，**CI** 全绿不代替这些证据。

2.4 本轮新增文档

本次实验新增两份文档：

- 本报告——项目中期完成情况；
- 第四次实验-单元测试与代码评审报告——单元测试与代码评审过程。

同时把两份文档登记进 文档维护索引，并统一了两个索引页的日期口径：文档更新日期为 **2026-10-12/13**，交付事实快照仍为 **2026-10-07**，因为 `HEAD` 与基线 `f2f60ec` 之间只有文档改动（已用 `git diff` 核对，无任何 `.py/.js/.html/.yml` 差异）。

三、界面完成情况

3.1 已完成界面

Web 端与 Windows 客户端共用同一套 Django 模板与前端资源，已实现并可用于演示的界面如下（截图见 screenshots，2026-10-01 采集）：

序号	界面	说明
01	登录页（二维码）	扫码登录入口
02	登录页（表单）	账号密码登录、注册入口
03	主界面	三栏布局：会话列表 / 聊天区 / 右侧面板
04	联系人	联系人列表、好友申请
05	群组	群列表、建群、群邀请
06	私聊（E2EE）	加密消息收发、状态标记
07	群聊	群消息、成员管理、群公告
08	设置中心	通用、通知、隐私安全、数据存储、语言、贴纸表情、会话快捷键、聊天文件夹、生日
09	AI Assistant	独立 AI 会话入口，支持多模型配置

界面支持明暗主题，并已针对 **3** 种窗口尺寸 **× 2** 种主题做真实 Chromium 布局回归（36/36 通过）。

3.2 界面相关的真实缺陷与修复

界面部分出过一类容易被忽略的问题：功能正确但布局被破坏。

- 现象：通知设置的预览开关会引起侧栏滚动约 695px，并挤压搜索头部；内嵌设置样式泄漏到聊天区。
- 发现方式：T18 评审复核 + 真实 Chromium 布局测试。
- 修复：PR #328，重新约束侧栏 flex 尺寸与聊天顶部定位。
- 验证：同一套 36 项布局用例在修复前的基线上失败，修复后通过；这是回归测试确实有效的证据，而不是"测试总是绿的"。
- 部署：合并为 `c23127f` 并部署到生产，生产 `health/live`、`health/ready`、`login` 均返回 200。

3.3 界面未完成部分

- 通知最终布局复验（**#145**）：正式登录客户端在修复后的预览切换、返回聊天与顶部位置复验尚未记录，该任务保持开放。不能用本地 fixture 或健康探针关闭它。
- 原生文件集成（**#146**）：桌面端原生文件选择、保存、打开及权限/失败路径尚未实施。
- **Android** 界面：无任何 Android 工程或界面适配，不能用窄屏浏览器测试代替真机验收。
- 移动端响应式：仅在浏览器层面验证，未在原生环境验证触控、返回键和生命周期。

四、代码完成情况

4.1 技术栈与规模

部分	实现
服务端	Python 3.13、Django 6.0.5、Channels 4.3.2、Daphne 4.2.1
数据库	本地 SQLite；生产 PostgreSQL 16（psycopg 3.3.6）
分发与缓存	本地内存；生产 Redis（channels-redis 4.3.0）
前端	Django 模板 + 原生 JavaScript + Web Crypto，自托管 Tailwind CSS
桌面	Electron 39 系列、electron-builder 25 系列、NSIS，版本 1.0.0
加解密	浏览器 Web Crypto；桌面 safeStorage（Windows DPAPI）

受控源码规模（按目录统计，含测试）：

目录	行数
`static/js/`（前端全部逻辑）	16,003
`templates/pages/`（22 个页面）	7,211
`chat/`（模型、视图、Consumer、AI）	6,444
`chat/tests/`（后端测试）	5,313
`accounts/`	3,521
`chat/services/`（统一消息服务、同步）	713
`ichat_pro/`（配置、ASGI、中间件、健康检查）	632
`desktop/`（Electron 主进程与配置）	567
`deploy/`（部署、备份、恢复脚本）	515
合计	约 **41,000**

计数口径：上表按目录统计 `.py`、`.js`、`.html`、`.sh`、`.md`、`.json`、`.cjs` 文件行数，合计 40,919 行。`README.md` 等仓库根目录文件、`docs/` 文档、`chat/migrations/` 与本表未计入。

数据库迁移：`chat` 21 个、`accounts` 15 个，`makemigrations --check` 无待生成变更。

4.2 已交付的核心代码能力

统一消息写入路径。 `chat/services/messaging.py` 是 HTTP 与 WebSocket 共用的唯一事务写入实现。事务顺序为：结构校验 → 会话行锁 → 身份/权限校验 → 幂等重放判定 → 新消息检查 → 插入 → 计数与事件。设计目标是两条入口不可能产生行为漂移——这是评审 R-03/R-04 风险后的整改结果。

幂等与并发。 `(sender, client_message_id)` 重放时，从持久化列重新计算内容摘要并比对，内容不同返回 409 而非错误重放。并发同 ID 插入依赖数据库唯一约束触发 `IntegrityError`，用嵌套 `atomic`（savepoint）只回滚 INSERT 而不破坏外层事务，然后恢复查询。合法重放不重复计未读、不重复广播、不重复生成事件。

增量补取。 `Conversation.sync_sequence` 与 `ConversationEvent` 在会话行锁内分配序号，保证并发发送不会撞号。游标用 HMAC-SHA256 签名并绑定用户与会话，TTL 7 天。补取的可见性投影与历史接口同源，包含清空、个人删除、自动删除、拉黑和群 pre-join 边界。

端到端加密边界。 长期私钥是 IndexedDB 中不可导出的 CryptoKey，服务端只中转和保存密文。桌面端待导出备份、聊天草稿与 AI 历史通过 safeStorage 加密；桥不可用时不新增明文写入。私聊保存接收者密文与发送者独立副本，群聊为每个有效成员保存独立密文。

协议与错误契约。 `chat/errors.py` 是错误码单一注册表（25 个已注册码），每个码定义 HTTP 状态、是否可重试和默认文案。客户端按码分支而不是按文案匹配。API 未登录返回 401 JSON 而非 HTML 重定向，WebSocket 用 4401/4003 关闭码。

桌面客户端。 默认连接云服务（`https://chat.20060810.xyz:8443`），不启动本地 Python；开发模式显式启用。单实例锁先于网络与启动服务，托盘隐藏/恢复同一窗口不重载页面，退出时清理进程与托盘。品牌 AUMID 与 `build.appId` 对齐。

运维与健康检查。 `/health/live/` 与 `/health/ready/` 公开响应只返回状态词，失败细节写日志而不泄露内部拓扑；readiness 实际探测数据库与缓存往返。部署统一使用仓库外稳定脚本，支持指定 SHA 回滚，回滚应用不会自动降级数据库。

4.3 代码管理

- 累计 **311** 次提交、**118** 个已合并 **PR**；
- 分支策略：`main` 保持可演示，功能/修复/测试/文档分支分别用 `feature/`、`fix/`、`test/`、`docs/` 前缀；
- 提交规范：类型 + 简述 + Issue 编号，类型为 `feat/fix/test/docs/refactor/chore/ci`；
- 敏感文件不入库：`.env`、数据库、媒体、私钥、Token、依赖与安装包均在 `.gitignore` 中。

4.4 自动化检查

GitHub Actions 在 PR 和 `main` 推送时运行四个 job：

job	内容
`test`	Django check、迁移一致性、SQLite 测试
`integration`	PostgreSQL 16 / Redis 7、迁移与测试
`javascript`	E2EE、连接、ACK、公钥缓存、桌面与通知回归
`windows-installer`	Chromium 布局、品牌资源、隔离 NSIS 检查

基线 run 37630595919 四项全部成功。

五、发现的 Bug 与修复

本节只列已经复现、修复并有回归验证的缺陷。

#	缺陷	影响	修复	验证
1	晚 ACK 错行：按新数组下标改旧	消息显示错误、丢行	PR #304，改为定位并重标临时行、	12 条 DOM 回归 + 真实双客户端断

#	缺陷	影响	修复	验证
	DOM，替换无关行（数组 `[43,44,45]`，DOM `[45,44,45]`）		按服务端时间排序、重建新旧两处分组	网 9.241s 恢复，数组与 DOM 均为 `[46,47,48,49]`
2	指定公钥版本被最新缓存版本替代	加密边界错误、密钥轮换回归	PR #304，显式版本必须精确命中缓存，无版本离线发送保留回退	`public_key_cache.test.js` 私聊/群聊各覆盖
3	卸载登记只按目录前缀匹配	可能误删相似路径的另一次安装、选错用户数据目录	PR #314，引号感知精确匹配、按 UninstallString 限定清理	24 项真实 NSIS 宏隔离断言
4	通知设置未就绪时泄露预览；未知会话未查静音即通知	隐私泄露	PR #326，门控改为未就绪即关闭，未知会话先读元数据	通知三套回归接入 CI
5	预览开关引起侧栏滚动 695px、内嵌设置样式泄漏	界面布局破坏	PR #328	布局 36 项，修复前基线失败、修复后通过
6	测试污染：头像测试向仓库 `media/avatars/` 写入真实文件	工作区持续堆积垃圾文件（累计 82 个可证明产物）	类级临时 `MEDIA_ROOT` + 类清理删除（本轮）	跑完整套件前后均为 6 个文件，临时目录无残留

其中第 1、2 项来自 AI 辅助分析 + 人工复核，过程记录见 AI 实践记录；第 6 项是本轮单元测试复核时发现的测试自身缺陷。

5.1 已识别但未修复的问题（风险登记 R-01–R-07）

项目在初期做过一次静态代码取证，确认 7 项风险并全部进入整改，当前均已闭环：

编号	问题	处置
R-01	私聊幂等命中先于会	权限先于幂等，跨会话

编号	问题	处置
	话/权限校验	ID 返回 409
R-02	群聊幂等查询在成员版本校验之后	合法重放先于当前成员版本处理
R-03	HTTP 与 WS 私聊序列化路径漂移	两条路径共用服务与 viewer 投影
R-04	幂等重放仍重复广播、无 created 区分	created/replayed 区分，重放零副作用
R-05	在线状态依赖非标准接口、异常被吞	改用缓存连接计数
R-06	API 认证失效返回 HTML 重定向	改为 401 JSON / WS 4401
R-07	生产配置缺口（代理信任/CSRF/静态收集/URL 静默回退）	非法 DATABASE_URL 启动失败，补代理与静态配置

5.2 尚未验证的边界

- 待发箱仅在内存，页面重载或进程重启不保证未确认消息恢复；
- 补取只覆盖部署后的新增消息，未回填历史，也未同步撤回/删除变更事件；
- 离线加密需要已缓存公钥，首次无缓存时不能离线建立新的加密收件关系；
- 未配置商业代码签名证书。

六、需求中期修改情况

6.1 结论

本学期需求主线没有发生方向性变更，也未删除任何原始需求。 中期发生的是优先级与范围口径的对齐，以及把原任务描述中含糊之处明确化。所有调整都记录在案，不静默改写原 Issue 范围。

6.2 需求基线

需求使用 `NEW-*` 编号，共 **114** 条，按族划分为：Windows 客户端（WIN，16）、Android 客户端（AND，16）、跨平台一致性（XP，8）、云端与运维（CLD，18）、消息可靠性（REL，11）、设备与 E2EE 边界（DEV，9）、测试与质量（TST，26）、持续集成与发布（CI，10）。

6.3 中期对齐的具体条目

冲突/含糊点	处理口径
原任务 T18 含通知跳转，优先级 P1；SRS WIN-009 为 P2	保留原任务 P1；通知主体先完成，跳转作为增强单独报告

冲突/含糊点	处理口径
T25 含返回键 P0；SRS AND-006 为 P1	生命周期恢复按 P0，基本返回行为随平台包实施，细化返回 UX 按 P1 验收
AND-009 前台提醒 P0，但 T27 整体 P1	前台提醒并入 Android 核心 P0，后台系统通知保持 P1
AND-016 为 P1，但 Test T04 要求两个配置	测试任务保持 P0，最终按两个配置准备证据
T54 依赖 P1 的 T50，Test T23 依赖 P1 的 T49	P0 至少提供独立测试环境、标准化冒烟、人工发布与回退手册；自动化发布增强仍按 P1，不绕过原依赖宣称全部完成
自动更新在需求中为 P2，但无独立任务编号	不虚构新任务号，后续挂靠 T16/T48 的子任务实现
原拆解把跨模块范围写成"P4 T14 ~ P4 Test T03"	工程任务与测试任务分开领取，以 `tasks.md` 逐行编号为准
SRS 继承章节含旧版本范围外表述	本学期新增按需求第 3 节；旧功能按现有代码回归，目标不缩减为旧版本

6.4 需求状态（中期）

对 114 条 `NEW-*` 需求的逐条状态判断（详见 需求追踪矩阵）：

状态	条数
已验收	9
已验证 / 已实现并验证 / 已回归	18
部分完成（有专项验收，未完整闭环）	32
待专项验收	18
未完成 / 待实施	25
其他（映射或过程性说明）	12
合计	**114**

需要强调：任务关闭不等于需求通过。工程卡关闭只表示该卡交付物完成，需求是否通过要看追踪矩阵的逐条判断。

6.5 范围外内容（明确不做）

语音/视频、iOS、完整 Signal/Double Ratchet/Sender Key 协议、Channel/Bot/RAG/Agent Gateway、商业审核与计费均不在本学期范围。已有 AI Assistant 保留独立边界，不影响核心聊天验收。

七、中期风险与后续计划

7.1 主要风险

风险	说明
Android 从零开始	9 项 P0/P1 任务全部未开始，是进度上最大的不确定性
测试工程缺口	无覆盖率、无静态/安全扫描、CI 不强制阻断合并
原生验收依赖环境	通知、安装、文件集成需要真实 Windows 环境和登录态，fixture 不能替代
单人多角色	评审记录集中在单一提交账号，多人独立评审的证据不足
监控与恢复	监控告警未完成，跨实例完整恢复未验收

7.2 后续优先级

1. 补完 **#145** 通知最终布局复验与 **#146** 原生文件集成；
2. 推进 Android 技术验证、工程骨架、APK 与跨端联调（#149–#157、#164）；
3. 补齐 CI 强制门禁、覆盖率、依赖与秘密扫描（#171–#177、#204）；
4. 推进跨平台威胁模型与设备级身份、撤销、多设备密钥分发（#165–#170）；
5. 完善测试计划、黑盒/白盒用例、性能与弱网测试、最终测试总结（#190–#203）。

八、结论

中期项目已经具备可安装、可公网访问、可真实跨设备加密通信的可用形态：云端服务与数据库已上线，Windows 客户端已完成安装/卸载/托盘/通知/连接恢复/敏感存储的验收，后端消息链路（统一写入、幂等、补取、排序）已闭环，文档体系完整且维护规则明确。

同时，项目尚未达到全部 **P0** 交付：Android 完全未开始，多设备与设备级安全未实现，测试工程质量门禁不完整，部分原生验收（通知布局、文件集成）仍在等待真实环境复验。

本轮新增的实际产出包括：修复了长期污染工作区的测试缺陷（累计 82 个可证明的测试产物）并清理；统一了文档索引的日期与基线口径；补齐了单元测试与代码评审的过程记录。代码与全部文档已提交。